

Risk Register Report

ISO 27001:2022 Annex A Compliant Risk Assessment | Generated: 2026-08-13 03:12

1. Executive Summary

This report presents the current state of the organization's risk register as of August 13, 2026. A total of **11 risks** have been identified, assessed, and tracked. The assessment methodology follows **ISO 27005:2022** risk assessment guidelines aligned with the **ISO 27001:2022 Annex A** control framework.

Total Risks	11
Critical	0
High	11
Avg Score	12.82

Assessment Methodology

Risk Scoring: Each risk is evaluated on a 5×5 matrix combining Likelihood (1-5) and Impact (1-5) as defined by ISO 27005:2022. The product yields a risk score from 1 to 25, classified as: Low (1-4), Medium (5-9), High (10-16), Critical (17-25).

ISO 27001:2022 Mapping: Each risk is mapped to relevant Annex A controls (93 controls across 14 themes). This enables audit-ready traceability between identified risks and applicable controls.

Risk Treatment: Risks exceeding the Medium threshold require a documented treatment plan (Avoid, Transfer, Mitigate, or Accept) with assigned ownership and review timeline.

2. Risk Register

The following table presents all 11 identified risks with their assessment scores, levels, and ISO 27001 control mappings.

ID	Category	Title	L	I	Score	Level	Controls	Treatment
RISK-20260813-2804	Technical	SQL Injection in Customer Portal	4	4	16	High	A.9.1, A.9.3, A.14.1, A.14.2	Mitigate
RISK-20260813-6708	Technical	Unpatched Critical CVE	3	5	15	High	A.12.6, A.12.4, A.9.12	Mitigate
RISK-20260813-8964	Legal	GDPR Compliance - Missing DPIAs	2	5	10	High	A.18.4, A.18.1, A.8.2	Mitigate
RISK-20260813-0340	Operational	Single Point of Failure - Database	3	5	15	High	A.11.11, A.12.1, A.17.1	Mitigate
RISK-20260813-2868	Personnel	Insider Threat - Unmonitored Privileged Access	3	4	12	High	A.9.3, A.9.4, A.12.4, A.7.3	Mitigate
RISK-20260813-7044	Third Party	Cloud Provider Data Breach Risk	2	5	10	High	A.6.2, A.15.1, A.15.2, A.13.4	Transfer
RISK-20260813-5236	Access Control	Shared Generic Admin Accounts	4	3	12	High	A.9.2, A.9.3, A.9.4, A.9.6	Mitigate
RISK-20260813-9844	Data Classification	Sensitive Data Without Encryption	3	4	12	High	A.8.2, A.8.3, A.10.1, A.10.2	Mitigate
RISK-20260813-4516	Physical Security	Unauthorized Physical Access to Server Room	3	4	12	High	A.11.1, A.11.2, A.11.3, A.11.4	Mitigate
RISK-20260813-7764	Cryptography	Weak Crypto in Legacy Systems	4	3	12	High	A.10.1, A.10.2, A.14.2	Mitigate
RISK-20260813-7108	Incident Response	No Documented Incident Response Plan	3	5	15	High	A.16.1, A.16.2	Mitigate

3. Risk Assessment Matrix

The 5×5 risk matrix below visualizes the distribution of risks across Likelihood × Impact dimensions. Each cell indicates the number of risks falling into that category.

Likelihood ↓ / Impact →	1 — Negligible	2 — Minor	3 — Moderate	4 — Major	5 — Severe
5 — Almost Certain	Score: 5 Level: Medium Count: 0	Score: 10 Level: High Count: 0	Score: 15 Level: High Count: 0	Score: 20 Level: Critical Count: 0	Score: 25 Level: Critical Count: 0
4 — Likely	Score: 4 Level: Low Count: 0	Score: 8 Level: Medium Count: 0	Score: 12 Level: High Count: 2	Score: 16 Level: High Count: 1	Score: 20 Level: Critical Count: 0
3 — Possible	Score: 3 Level: Low Count: 0	Score: 6 Level: Medium Count: 0	Score: 9 Level: Medium Count: 0	Score: 12 Level: High Count: 3	Score: 15 Level: High Count: 3
2 — Unlikely	Score: 2 Level: Low Count: 0	Score: 4 Level: Low Count: 0	Score: 6 Level: Medium Count: 0	Score: 8 Level: Medium Count: 0	Score: 10 Level: High Count: 2
1 — Rare	Score: 1 Level: Low Count: 0	Score: 2 Level: Low Count: 0	Score: 3 Level: Low Count: 0	Score: 4 Level: Low Count: 0	Score: 5 Level: Medium Count: 0

Risk Level Thresholds (ISO 27005:2022):

- **Low (1-4):** Accept — monitor periodically
- **Medium (5-9):** Mitigate — action plan required
- **High (10-16):** Mitigate urgently — escalation required
- **Critical (17-25):** Immediate action — executive escalation

4. ISO 27001:2022 Annex A — Control Coverage

This section maps identified risks to applicable ISO 27001:2022 Annex A controls. This mapping enables audit-ready traceability and demonstrates that risk management is integrated with the organization's information security control framework.

Control Ref	Control Title	Theme	Mappe d
A.5.1	Policies for information security	5 Policies for information security	—
A.5.2	Information security roles and responsibilities	5 Policies for information security	—
A.5.3	Segregation of duties	5 Policies for information security	—
A.6.1	Information security in project management	6 Organisation of information security	—
A.6.2	Information security in supplier relationships	6 Organisation of information security	✓ Yes
A.6.3	Information security in project management	6 Organisation of information security	—
A.7.1	Screening	7 Human resource security	—
A.7.2	Terms and conditions of employment	7 Human resource security	—
A.7.3	Information security awareness, education and training	7 Human resource security	✓ Yes

Control Ref	Control Title	Theme	Mappe d
A.7.4	Disciplinary process	7 Human resource security	—
A.7.5	Responsibilities after termination or change of employment	7 Human resource security	—
A.8.1	Inventory of information and associated assets	8 Asset management	—
A.8.2	Classification of information	8 Asset management	✓ Yes
A.8.3	Labelling of information	8 Asset management	✓ Yes
A.8.4	Handling of assets	8 Asset management	—
A.8.5	Return of assets	8 Asset management	—
A.9.1	Access control policy	9 Access control	✓ Yes
A.9.2	User registration and de-registration	9 Access control	✓ Yes
A.9.3	Management of privileged access rights	9 Access control	✓ Yes
A.9.4	Access rights	9 Access control	✓ Yes
A.9.5	Information access restriction	9 Access control	—
A.9.6	Identity management	9 Access control	✓ Yes
A.9.7	Authentication information	9 Access control	—
A.9.8	Devices and systems authentication	9 Access control	—

Control Ref	Control Title	Theme	Mappe d
A.9.9	Restrictions on the use of external devices and systems	9 Access control	—
A.9.10	Secure log-on procedures	9 Access control	—
A.9.11	Password management system	9 Access control	—
A.9.12	Use of privileged utility programs	9 Access control	✓ Yes
A.9.13	Access to program source code	9 Access control	—
A.10.1	Policy on the use of cryptographic controls	10 Crypt ography	✓ Yes
A.10.2	Key management	10 Crypt ography	✓ Yes
A.11.1	Physical security perimeter	11 Physical and envi ronment al security	✓ Yes
A.11.2	Physical entry controls	11 Physical and envi ronment al security	✓ Yes
A.11.3	Securing offices, rooms and facilities	11 Physical and envi ronment al security	✓ Yes
A.11.4	Physical security monitoring	11 Physical and envi ronment al security	✓ Yes
A.11.5	Protecting against physical and environmental threats	11 Physical and envi ronment al security	—

Control Ref	Control Title	Theme	Mappe d
A.11.6	Working in secure areas	11 Physical and environment al security	—
A.11.7	Clear desk and clear screen policy	11 Physical and environment al security	—
A.11.8	Equipment siting and protection	11 Physical and environment al security	—
A.11.9	Security of assets off-premises	11 Physical and environment al security	—
A.11.10	Secure disposal or reuse of equipment	11 Physical and environment al security	—
A.11.11	Backup	11 Physical and environment al security	✓ Yes
A.12.1	Designing and operating controls for IT facilities	12 Oper ations security	✓ Yes
A.12.2	Controls for IT supply chain	12 Oper ations security	—
A.12.3	Information systems audit considerations	12 Oper ations security	—
A.12.4	Logging and monitoring	12 Oper ations security	✓ Yes
A.12.5	Protection of operational systems	12 Oper ations security	—

Control Ref	Control Title	Theme	Mappe d
A.12.6	Management of technical vulnerabilities	12 Operations security	✓ Yes
A.12.7	Configuration management	12 Operations security	—
A.12.8	Information systems acceptance	12 Operations security	—
A.13.1	Network security management	13 Communications security	—
A.13.2	Security of network services	13 Communications security	—
A.13.3	Segregation of networks	13 Communications security	—
A.13.4	Encryption and integrity protection of data during transmission	13 Communications security	✓ Yes
A.14.1	Securing applications before deployment	14 System acquisition, development and maintenance	✓ Yes
A.14.2	Secure software development	14 System acquisition, development and maintenance	✓ Yes
A.14.3	Secure development environment	14 System acquisition, development and maintenance	—

Control Ref	Control Title	Theme	Mappe d
A.14.4	System security testing	14 System acquisition, development and maintenance	—
A.14.5	Outsourced development	14 System acquisition, development and maintenance	—
A.14.6	Security of service-oriented architectures	14 System acquisition, development and maintenance	—
A.15.1	Information security in supplier relationships	15 Supplier relationships	✓ Yes
A.15.2	Monitoring and review of supplier services	15 Supplier relationships	✓ Yes
A.16.1	Management of information security incidents	16 Information security incident management	✓ Yes
A.16.2	Collection of evidence	16 Information security incident management	✓ Yes
A.17.1	Planning information security continuity	17 Information security aspects of business continuity management	✓ Yes

Control Ref	Control Title	Theme	Mappe d
A.17.2	Implementing information security continuity	17 Information security aspects of business continuity management	—
A.17.3	Verification, review and evaluation of information security continuity	17 Information security aspects of business continuity management	—
A.18.1	Identification of applicable legislation and contractual requirements	18 Compliance	✓ Yes
A.18.2	Intellectual property rights	18 Compliance	—
A.18.3	Protection of records	18 Compliance	—
A.18.4	Privacy and protection of PII	18 Compliance	✓ Yes
A.18.5	Independent review of information security	18 Compliance	—
A.18.6	Compliance with security policies, rules and standards for information security	18 Compliance	—

5. Risk Treatment Plan — High & Critical Risks

The following treatment plan addresses all risks classified as High or Critical. Each entry includes the selected treatment strategy, mitigation actions, assigned owner, and required timeline.

Risk ID	Title	Level	Score	Treatment	Mitigation Plan	Owner	Review Date
RISK-20260813-2804	SQL Injection in Customer Portal	High	16	Mitigate	1. Implement parameterized queries 2. Conduct pentesting 3. Deploy WAF	Web Development Team	2024-06-15
RISK-20260813-6708	Unpatched Critical CVE	High	15	Mitigate	1. Apply patch within 48 hours 2. Network mitigations 3. SIEM monitoring	Infrastructure Team	2024-03-01
RISK-20260813-8964	GDPR Compliance - Missing DPIAs	High	10	Mitigate	1. Conduct DPIAs 2. Engage DPO 3. Privacy-by-design	Data Protection Officer	2024-04-01
RISK-20260813-0340	Single Point of Failure - Database	High	15	Mitigate	1. DB replication 2. Auto failover 3. Backup procedures	Infrastructure Team	2024-04-15
RISK-20260813-2868	Insider Threat - Unmonitored Privileged Access	High	12	Mitigate	1. PAM solution 2. Audit logging 3. Quarterly access reviews	IT Security Team	2024-05-01
RISK-20260813-7044	Cloud Provider Data Breach Risk	High	10	Transfer	1. Review SLA 2. Customer-managed encryption keys 3. Annual assessment	Cloud Infrastructure Team	2024-05-15
RISK-20260813-5236	Shared Generic Admin Accounts	High	12	Mitigate	1. Document shared accounts 2. Create named accounts 3. Implement RBAC	IT Security Team	2024-06-01
RISK-20260813-9844	Sensitive Data Without Encryption	High	12	Mitigate	1. TDE on all DBs 2. Data classification policy 3. Anonymize non-prod PII	DB Administration Team	2024-05-20
RISK-20260813-4516	Unauthorized Physical Access to Server Room	High	12	Mitigate	1. Electronic access control 2. Access logging 3. CCTV	Facilities Management	2024-06-01
RISK-20260813-7764	Weak Crypto in Legacy Systems	High	12	Mitigate	1. Crypto inventory 2. Replace with SHA-256/AES-256 3. Update standards	Application Dev Team	2024-09-15
RISK-20260813-7108	No Documented Incident Response Plan	High	15	Mitigate	1. Develop IR plan (NIST SP 800-61) 2. Severity classification 3. Tabletop exercise	IT Security Team	2024-06-20